Computer Security — Written Practice Questions

MAIN TEST · Classic written-answer questions in the style of the teacher's *Midterm Guidance* · Weeks 1–6 · 78 questions · Model answers at the end

Name: _____ **Student ID:** _____

About these questions. The teacher's guidance asks open questions such as "*Can you distinguish threat, vulnerability, exploit, control, risk and incident, and identify each one in a scenario?*" These practice questions follow that style: **define**, **distinguish**, **identify in a scenario**, **explain why**, **choose a control or response**. They use new scenarios, so you practise applying the ideas, not memorizing the guidance sheet.

Write in short, clear sentences. A good answer names the term, applies it to the scenario, and gives the reason. Model answers are at the end.

Week 1 — Introduction to Computer Security

1. What do confidentiality, integrity and availability mean? Give one university example for each.

2. Name the main CIA goal affected in each scenario:

a. A classmate reads your e-mail on your unlocked laptop.
b. A grade is changed from 55 to 85 without permission.
c. The campus Wi-Fi router fails an hour before an online exam.
d. A submitted assignment file is corrupted and cannot be opened.

3. Choose one suitable control for each scenario in question 2 and explain how it helps.

4. Name one control that supports more than one CIA goal and explain how.

5. What does computer security protect? Give three areas with examples.

6. A power failure stops the library's room-booking system for a day. Nobody attacked it. Why is this still a security problem, and which goal is affected?

7. A phishing e-mail reaches university staff. Explain how **people**, **process** and **technology** each help to stop the attack.

8. What is defense in depth? Give four layers that protect a student's university account.

9. MFA makes logging in slower. Why is this a balance problem, and how should it be handled?

10. What makes a security test authorized? Name the five things it must have.

11. A friend says: "The department server is reachable from the dorm Wi-Fi. Let's test it for weaknesses." What should you do, and why?

12. Explain pause, check and report for a suspicious message. What do you do at each step?

Week 2 — Assets, Threats and Risk

1. Classify each asset as information, device, people or service: (a) the student-records database, (b) a hospital nurse, (c) the online tuition-payment system, (d) a laptop used in the clinic, (e) the LMS, (f) the file containing next week's exam questions.

2. Explain the **value** and the **dependencies** of the LMS. What makes it valuable, and what does it need in order to work?

3. Define threat, vulnerability, exploit, control, risk and incident in one sentence each.

4. *Scenario:* "The course-registration website runs an outdated plug-in with a publicly known flaw. Attackers scan the Internet, use the flaw, and change students' timetables. The IT team then installs the update and checks that it works." Identify the asset, threat, vulnerability, exploit, control, incident and the CIA goal affected.

5. Give one example of a malicious, an accidental and a physical threat to a university data center, and explain how each could harm an asset.

6. What is the difference between an incident and a risk? Give one example of each.

7. *Scenario:* students' passwords are stored in plain text in a spreadsheet on a shared drive that 300 staff can open. Rate likelihood and impact (1–3), calculate the score, give the level, and justify your ratings.

8. Calculate the score and level: (a) L 1, I 2; (b) L 2, I 2; (c) L 3, I 2; (d) L 1, I 3; (e) L 3, I 3. Why can a score of 5 never appear?

9. Why does a verified patch mainly reduce **likelihood**, while a successful tested restore mainly reduces **impact**?

10. Why must a patch be **verified** and a backup **tested**? Use the Equifax and GitLab cases.

11. Give one **prevent**, one **detect** and one **recover** control for an online exam system.

12. Compare Uber (September 2022) and Cloudflare (2022). Why did the attacker get in at one company but not the other?

Week 3 — Social Engineering and Phishing

1. What is social engineering? Explain why it works, using trust, pressure and attention.

2. *Message:* "Hi, it's Professor Kim. I'm stuck in a meeting and need you to buy three gift cards for the department right now. Don't tell anyone; I'll pay you back today." Identify the invented story, the requested action and every lever used.

3. Name the main lever in each: (a) "You have been selected for a free laptop." (b) "Police: your account is being used for money laundering." (c) "Only 5 minutes left to confirm." (d) "Mom, my phone broke, this is my new number." (e) "See who viewed your profile." (f) "This is the IT director."

4. Define phishing, spear phishing, smishing, vishing and impersonation.

5. Label each attack (more than one label may fit): (a) an SMS using your name and a parcel number, pretending to be a delivery company; (b) a phone call from a fake prosecutor; (c) a generic e-mail saying "Your mailbox is full"; (d) a copied Instagram account of your friend asking for money.

6. Why can one message fit more than one label?

7. Explain baiting and tailgating with one campus example each, and give the correct response.

8. What is a deepfake? Why should a familiar face or voice still be checked before a sensitive action? Refer to a real case.

9. List every warning sign in this message:

```
From: KSU IT Support <it-ksu@ksu-helpdesk.example.net>
Subject: URGENT – your account will be deleted in 1 hour
Click https://portal.kyungsung.example.login-verify.test to keep your account
and enter your password and the OTP code we send you.
```

10. Which addresses really belong to `kyungsung.example`? Explain how you decided. (a) `https://lms.kyungsung.example/login` (b) `https://kyungsung.example.lms-login.test` (c) `https://kyungsung-example.com` (d) `https://mail.kyungsung.example`

11. Why do a familiar name, a logo, fluent writing or HTTPS fail to prove that a request is genuine?

12. What is an **independent** official route? Give an example for a message that claims to be from your bank and one that claims to be from the university.

13. What should you do in each case? (a) You typed your password into a fake page. (b) You approved a login you did not start. (c) You installed an app a caller asked for. (d) You sent money to a scammer.

14. In South Korea, which route do you use for: (a) money already sent / active voice phishing, (b) a suspicious SMS or app, (c) a university account problem?

Week 4 — Identity, Authentication and Access Control

1. Distinguish identification, authentication and authorization. Use Mina signing in to the LMS as the example.

2. *Scenario:* an attacker signs in with Mina's stolen password and opens Joon's grade record. Which check passed, which check failed, and what evidence would you collect?

3. How do an account, a session and a permission differ? Give one failure example for each.

4. How do password guessing and credential stuffing differ? Give one defense for each.

5. Compare online and offline guessing. Where do login attempt limits help, and where do they not help?

6. How many possible values do a four-digit PIN and a six-digit PIN have? Besides the number of possibilities, what else decides how long guessing takes?

7. In the CyberChef activity, why do we say "the hash was **not** decrypted"? Why does a short list that fails to match not prove a password is safe?

8. What do a unique salt and a password-hashing scheme such as Argon2id each do? Does the salt need to be secret?

9. Why use long, unique passwords and a password manager instead of reusing passwords? Explain how one leaked forum password could spread to other accounts.

10. Name the three MFA factor types with examples. Then classify each as MFA or not: (a) password + SMS code, (b) password + security question, (c) fingerprint + PIN, (d) security key + PIN, (e) PIN + password.

11. Why must protected pages check that MFA is complete? Describe what went wrong in the "2FA simple bypass" lab and the correct rule.

12. What should you do with an unexpected login approval request, and why? Refer to the Uber case.

13. Explain roles, scope and least privilege for a student, a TA and a lecturer. What should happen to the TA's access when the semester ends?

14. Distinguish horizontal and vertical access failures. Then find the violation(s) in this log and name the type:

Time	Account	Event	Decision
14:01	ta.park (section A)	Edit grade, section A	Allow
14:03	ta.park (section A)	Edit grade, section B	Allow
14:05	student.choi	Read own grade	Allow
14:06	student.choi	Change course settings	Allow
14:07	student.choi	Read student.han's grade	Deny

Week 5 — Malware and Endpoint Security

1. What is malware? Why is it identified by its behavior and purpose rather than its name or appearance?

2. Identify the type: (a) spreads through the network to unpatched computers without anyone clicking; (b) a "free Photoshop" download installs remote-access software; (c) encrypts files and demands bitcoin; (d) records every keystroke; (e) an infected program on a USB stick infects other programs when it is run; (f) a PC sends spam whenever a remote operator commands it.

3. How do a virus and a worm spread differently? Give the slide example of each.

4. Why do symptoms alone (for example "my laptop is slow") not prove infection? What evidence should be collected?

5. How can malware stay hidden or combine several types? Use a fake software update as the example.

6. Name a suitable control for each infection path: (a) e-mail attachment, (b) fake update, (c) unpatched service, (d) unknown USB device, (e) compromised supplier.

7. Write the infection story for a USB stick found in the library, stage by stage (initial contact, execution, privilege, persistence, impact, recovery), with one control at each stage.

8. *Scenario:* in a small office, staff work as administrators, automatic updates are turned off, there is no endpoint protection, and the only backup drive is always connected. Recommend controls for each weakness.

9. Why is antivirus alone not enough?

10. Why must backups be protected, separated and tested?

11. What does "returning to a trusted state" mean? Why must recovery also fix the original weakness?

12. You suspect your lab PC is infected. What should you do, what should you not do, and why?

Week 6 — Networking Fundamentals for Security

1. What distinguishes a LAN, a WAN and the Internet? Give one example of each.

2. The campus Internet connection fails. Can you still print to the lab printer? Explain using the path of the print job.

3. Trace a request from a laptop on Wi-Fi to the cloud LMS. What does each device on the path do? What is the default gateway?

4. What is the difference between a switch and a router?

5. What do an IP address, a port, a protocol and DNS each do? Does an IP address prove who a person is?

6. Distinguish private and public addresses, and explain what NAT does. Classify: `192.168.10.24`, `203.0.113.5`, `10.0.0.8`.

7. Which services use ports 443 and 22? Write the firewall rules you would use for a public web server that only IT administers.

8. Identify the scheme, domain and path in `https://portal.kyungsung.example/grades/2026`. Which port is used, and why?

9. Explain the basic roles of IP, TCP, HTTP and TLS. What is HTTPS?

10. How does HTTPS protect data in transit? Why can a phishing site still use HTTPS, and why does HTTPS not protect an infected endpoint?

11. Name the risk and where it occurs: (a) a fake access point called `KSU_Free_WiFi`; (b) a false DNS answer sends `lms.example.com` to the attacker's address; (c) someone on the same network reads plain HTTP traffic; (d) the printer's admin page is reachable from the Internet.

12. Why does DNS spoofing not automatically defeat a correct HTTPS connection?

13. Place a suitable control at each location for a small office: device, Wi-Fi access, boundary, data in transit, server.

14. At a café you see a certificate warning for the campus portal. What should you do, and what could be causing it?

Model Answers

Week 1

1. Confidentiality = only authorized people can see information (only the student and staff see a grade). **Integrity** = information is correct, complete and trustworthy (an assignment arrives exactly as submitted). **Availability** = authorized people can use it when needed (the LMS works before a deadline).

2. a. Confidentiality. b. Integrity. c. Availability. d. Integrity (and, as a result, availability).

3. a. Screen lock / log out: no one else can read the e-mail (C). b. Access control so only authorized staff can edit grades, plus logs or version history to detect changes (I). c. Redundancy (a backup network link or second router) and monitoring (A). d. A tested backup or version history to restore the correct file (I, A).

4. A **tested backup**: it keeps data available after a failure (A) and restores the correct version after unwanted change (I). (Access control also supports C and I.)

5. Information (grades, messages, research, identity and payment data); devices and services (phones, laptops, LMS, e-mail, cloud storage, campus Wi-Fi); people and reputation (time, trust, privacy, safety, the ability to study or work).

6. Security also covers harmful disruption, whatever the cause. Authorized people cannot use the system when needed, so **availability** failed. Accidents and technical failures cause real harm just like attacks.

7. People: staff recognize warning signs, do not click, and report it. **Process**: a clear rule ("IT never asks for passwords") and a reporting channel. **Technology**: e-mail filtering, MFA so a stolen password is not enough, logging and alerts. Technology alone fails if a person gives the password away.

8. Several layers of protection, because any single control can fail and another layer catches what it misses. Example layers: an attentive user, a long unique password, MFA, an updated device with endpoint protection, network controls, monitoring of logins, backups.

9. More protection adds effort (an extra login step), so people may try to avoid it. The answer is to make protection **usable** (e.g. a fast authenticator or passkey), not to remove it. Avoid both "nothing happened, so we are safe" and "everything is a disaster".

10. A clear **owner** who gives permission, a defined **scope**, an agreed **time**, approved **methods** and a stated **purpose**, with results handled privately.

11. Do not test it. Reachable does not mean allowed: there is no permission from the owner and no agreed scope. The same scan can be ethical in an approved lab and unauthorized here. If you think there is a problem, report it to the IT office.

12. Pause: do not click, reply, install or share; pressure is a signal to slow down. **Check**: verify the sender, request, address and context through a route you choose (open the official site yourself). **Report**: use the official channel (e.g. university IT).

Week 2

1. a. Information. b. People. c. Service. d. Device. e. Service. f. Information.

2. Value: students and staff rely on it for materials, submissions and grades, especially near deadlines; that comes from what it does, not its cost. Dependencies: servers, the network and Internet, DNS, accounts and authentication, power, and the data it stores. If a shared dependency fails, the services fail together.

3. Threat: a possible cause of harm. **Vulnerability**: a weakness that could be used. **Exploit**: a way to use a weakness. **Control**: a protective measure. **Risk**: possible future harm judged by likelihood and impact. **Incident**: something that has happened and harms or threatens security.

4. Asset: the course-registration website and timetable data (a service and information). Threat: the attackers. Vulnerability: the outdated plug-in with a known flaw. Exploit: using the flaw to get in and change data. Incident: the timetables were changed. Control: installing the update and **verifying** it (prevent). CIA goal: **integrity**.

5. Malicious: ransomware encrypts the servers, so services stop (availability). Accidental: an administrator deletes the wrong database (integrity). Physical: a fire or flood damages hardware (availability, possibly integrity).

6. An **incident** has already happened (yesterday ransomware encrypted the lab PCs). A **risk** is possible future harm (an unpatched server could be attacked before the exam).

7. Model: likelihood **3** (300 people can open it, plain text, no extra control, so misuse or leakage is expected); impact **3** (every student account can be taken over, harm is hard to reverse) → **9, High**. (L 2 × I 3 = 6, High, is also acceptable if justified.) Controls: remove the file, store passwords as salted Argon2id hashes, restrict access.

8. a. 2 Low. b. 4 Medium. c. 6 High. d. 3 Medium. e. 9 High. Ratings are 1, 2 or 3, and no product of two of them equals 5. Bands: 1–2 Low, 3–4 Medium, 6–9 High.

9. A verified patch closes the weakness that the attack route uses, so the harmful event becomes less likely; if it still happens another way, the damage is unchanged. A tested restore does not stop the event, but less is lost and service returns sooner, so the consequence is smaller.

10. Equifax: a patch instruction existed, but the flaw was not fixed on the real system, so data was exposed. A patch counts only once it is applied and checked. GitLab: after data was deleted by mistake, backups did not work as expected. A backup you have never restored from is only an assumption.

11. Prevent: patch the exam system / require MFA. Detect: monitor logs for unusual access or changes. Recover: restore from a tested backup.

12. Uber: the attacker had the password and sent repeated MFA push requests; a contractor approved one, so the control depended on a person's judgment under pressure. Cloudflare: staff entered details on a fake site, but **origin-bound security keys** checked which website was asking and refused, so stolen details were not enough.

Week 3

1. Deception that influences a person's action: it attacks the human factor, not the code. **Trust**: we cooperate with familiar people. **Pressure**: fear or a deadline narrows attention. **Attention**: a busy moment interrupts checking.

2. Story: the professor is stuck in a meeting and needs gift cards for the department. Action: buy gift cards (send money). Levers: **authority** (professor), **urgency** ("right now"), **secrecy** ("don't tell anyone"), **familiarity** (a known name), reward (repayment).

3. a. Reward. b. Fear (and authority). c. Urgency. d. Familiarity. e. Curiosity. f. Authority.

4. Phishing: deceptive contact that seeks information or an unsafe action. **Spear phishing**: personalized to a person, role or group. **Smishing**: by SMS/text. **Vishing**: by voice call. **Impersonation**: pretending to be someone else.

5. a. Smishing + spear phishing + impersonation. b. Vishing + impersonation. c. Broad phishing. d. Impersonation.

6. Each label describes a different feature (deception, targeting, channel, claimed identity), so one message can carry several.

7. Baiting: an attractive item or offer invites a risky action (a USB labelled "Exam answers"); do not plug it in, hand it to IT. **Tailgating**: following an authorized person into a restricted area (a visitor asks you to hold the lab door); politely direct them to reception or call their host.

8. AI imitation of a person's face or voice. Seeing a face raises confidence, but **recognition is not authorization**. In the Hong Kong case (reported 2024), staff joined a fabricated video meeting with a fake CFO and transferred about HK$200 million. Sensitive requests need an independent check through the normal approval process.

9. Sender domain `ksu-helpdesk.example.net` is not the university's; **urgency** and a threat ("deleted in 1 hour"); the link belongs to `login-verify.test` (read from the right), not `kyungsung.example`; it asks for a **password and OTP code** (sensitive action); unexpected contact. U + P + S are all present.

10. (a) and (d) belong to `kyungsung.example`: reading the hostname from the right, it ends in `kyungsung.example`. (b) belongs to `lms-login.test`; (c) is a different domain, `kyungsung-example.com`.

11. They are easy to imitate: names and logos can be copied, fluent writing is easy (and AI-generated), and HTTPS only protects the connection, including a connection to a deceptive site. They do not show that the request passed a real verification process.

12. A route you obtained **separately** from the suspicious contact, not from the message itself. Bank: call the number on the back of your card or open the bank app yourself. University: type the known portal address or call the IT office number from the official website.

13. a. Reset the password and end sessions through the official service, then contact IT. b. Same: report to IT, reset credentials, revoke sessions, check MFA settings. c. Stop using the device for sensitive tasks and get help from **another** device. d. Call 112 and your bank immediately to request payment suspension.

14. a. **112** and the bank's official contact. b. **118 (KISA)**. c. The known **university IT office**.

Week 4

1. Identification: Mina claims an account ("mina.student"). **Authentication**: she proves it with accepted proof (password, MFA). **Authorization**: the system decides whether that account may do the requested action (read her own grade yes, edit grades no).

2. Authentication passed (the stolen password was valid proof), so it cannot show who really typed it. **Authorization failed**: a student may read only her own record, so Joon's record should have been denied (horizontal failure). Evidence: the access log (time, account, event, decision) and active sessions.

3. Account record stores role, status and scope (failure: a former TA's account stays active). **Session** recognizes later requests after sign-in (failure: a stolen session is reused). **Permission** check decides access to each resource (failure: one student reads another's data).

4. Guessing tries likely passwords (`123456`); defense: attempt limits and strong passwords. **Credential stuffing** reuses a username–password pair leaked from another site; it works only on reused passwords; defense: a unique password per service (and MFA).

5. Online: guesses go to the login service, so attempt limits, monitoring and MFA help. **Offline**: the attacker tests guesses against a **copied hash** on their own device; the server's limits are never asked, so they do not help. Slow hashing (Argon2id), salts and long passwords help.

6. 10,000 and 1,000,000. The time also depends on the **guessing rate** and the **defenses** (attempt limits, slow hashing).

7. A hash is one-way. The attacker hashed each candidate word and one output matched the target, so the **guess** was correct. A short list that fails only shows those few words are wrong; a larger list or a different method could still succeed.

8. A unique random **salt** makes identical passwords produce different hashes, so one hash cannot be reused; it is stored with the hash and **does not need to be secret**. **Argon2id** makes each guess cost configured time and memory, which slows offline guessing (fast SHA-256 alone allows rapid guesses).

9. Long passwords resist guessing (NIST: at least 15 characters for password-only sign-in); unique passwords stop one leak from spreading; a manager makes this practical. If the forum leaks and the same password is used on the LMS, the leaked pair works there too (credential stuffing); an e-mail account with a different generated password is safe.

10. Know (password, PIN, security answer), have (phone, authenticator app, security key), are (fingerprint, face). a. MFA (know + have). b. Not MFA (know + know). c. MFA (are + know). d. MFA (have + know). e. Not MFA (know + know).

11. Showing a verification page does not enforce anything. In the lab the password was accepted, no code was entered, but requesting the account page directly opened it: the app did not check MFA state. Correct rule: no session → deny; password accepted but MFA pending → require the second factor; MFA complete **and** permission valid → allow.

12. Deny it and check the account through the official service, then report it. An unexpected prompt means someone may already have your password. At Uber, an attacker sent repeated prompts until a tired contractor approved one (MFA fatigue).

13. Roles grant actions; **scope** limits resources; **least privilege** gives only what the assignment needs. Student: read own grade, no edits. TA: read/edit grades for the assigned section only. Lecturer: manage the assigned course only. At the end of the semester the TA's scope is removed (change/leave), and sessions are revoked.

14. Horizontal = another user's resource at the same level; vertical = a more privileged action. **14:03** ta.park edits section B: outside the assigned scope → **horizontal**. **14:06** a student changes course settings → **vertical**. 14:07 was correctly denied; 14:01 and 14:05 are allowed by policy.

Week 5

1. Software intentionally designed to cause harm: steal information, disrupt service, spy, gain control or enable later attacks. Names and appearance can be faked or changed, and symptoms vary; what the software **does** defines it.

2. a. Worm. b. Trojan. c. Ransomware. d. Spyware (keylogger). e. Virus. f. Bot.

3. A **virus** activates when an infected file or program is executed and copies itself into other content, so it needs a user to run or share it (Sality). A **worm** spreads by itself across networks by exploiting weaknesses in reachable, unpatched systems, with no user action (Conficker; WannaCry also spread like a worm).

4. Slowness, pop-ups or crashes can come from ordinary faults, and some malware shows no sign at all. Collect: running processes, network connections, recent changes, startup and configuration changes, and scan results.

5. Spyware, bots and Trojans are designed to stay quiet; only ransomware wants to be seen. A fake update (Trojan) can install a keylogger (spyware) that steals passwords and later download ransomware: three types in one attack.

6. a. Verify unexpected content, e-mail filtering, user reporting. b. Approved sources only; check the publisher and update path; restrict installation. c. Patch quickly, prioritizing internet-facing systems; segmentation. d. Do not connect found devices; media policy; disable auto-run. e. Trusted, signed sources; track dependencies and supplier notices.

7. Contact: a student plugs in a found USB (control: media policy, hand it to IT). Execution: they open a file that runs the malware (control: disable auto-run, endpoint protection). Privilege: it runs with admin rights (control: standard accounts). Persistence: copies itself and adds a startup entry (control: monitor configuration changes). Impact: infects other files and media, steals data (control: segmentation, protected backups). Recovery: clean the system, fix the cause, reset credentials, restore, monitor.

8. Admin accounts → standard accounts for daily work (least privilege). Updates off → automatic updates for OS, apps and firmware; track devices that cannot update. No endpoint protection → install it and investigate alerts. Always-connected backup → a protected, **separated** (offline/offsite) backup that is **tested** regularly.

9. No tool detects every threat, and detection quality changes over time. Protection also depends on updates, configuration, privilege, backups and users (defense in depth).

10. Protected so attackers cannot change or delete them; **separated** because ransomware can encrypt a connected backup too; **tested** because only a successful restore proves the backup works (GitLab).

11. A trusted state = clean system → weakness fixed → credentials safe → data restored → monitored afterwards. If the original weakness is not fixed, restoring files can restore the same hole and the malware returns.

12. Do: stop sensitive work (no logins, no banking), report quickly to IT, follow their guidance. Do not: keep experimenting, delete files or disconnect critical systems on your own, because it can cause more harm and destroy evidence that staff need. Reset passwords used on the PC from a **different** trusted device.

Week 6

1. LAN: a network in a limited local area (computers and a printer in one lab). **WAN**: links networks over larger distances (a university linking two cities). **Internet**: many connected networks worldwide (campus reaching a cloud LMS).

2. Yes. Laptop → access point → switch → printer: the job stays on the local network and never needs the Internet. Wi-Fi connects you to a network, not necessarily to the Internet.

3. Laptop (client starts the request) → **access point** (lets the wireless device join) → **switch** (forwards Ethernet frames inside the LAN using MAC addresses) → **router/firewall** (forwards IP packets to other networks and filters traffic) → **Internet routers** → **LMS server** (provides the service). The **default gateway** is the router the laptop sends traffic to when the destination is on another network.

4. A **switch** connects devices inside one LAN (frames, MAC addresses). A **router** connects different networks (IP packets). A home "Wi-Fi router" combines router, access point and switch.

5. IP address: where is it? It identifies a network interface. **Port**: which service? **Protocol**: which rules? **DNS**: which address matches this name? An IP address does **not** prove a person's identity.

6. Private addresses are used inside local networks and are not directly routable on the Internet; **public** addresses are globally routable. **NAT** changes address information at the boundary, so many private addresses share one public address. `192.168.10.24` private, `203.0.113.5` public, `10.0.0.8` private.

7. 443 = HTTPS; 22 = SSH. Rules: allow 443 from anyone to the web server; deny 22 from the public Internet; allow 22 only from the approved admin network/VPN; deny everything else (default deny).

8. Scheme `https`, domain `portal.kyungsung.example`, path `/grades/2026`. Port **443**, the default for HTTPS when none is written.

9. IP delivers packets between networks. **TCP** delivers data reliably and in order. **HTTP** defines web requests and responses. **TLS** protects the connection: encryption and certificate checks. **HTTPS = HTTP protected by TLS.**

10. TLS encrypts the content between the two TLS endpoints, so a nearby observer cannot normally read it, and the certificate lets the browser check the server's name. A phishing site can obtain a valid certificate for **its own** domain, so HTTPS does not prove honesty. On an infected device, malware reads data before encryption or after decryption, so HTTPS does not help. IP addresses and timing may also stay visible.

11. a. **Evil twin**, at Wi-Fi access. b. **DNS spoofing**, at DNS. c. **On-path attacker**, in transit (plain HTTP is exposed). d. **Unnecessarily exposed service**, at the boundary/device (fix: firewall rules, update or restrict the printer).

12. The attacker's server still needs a valid certificate for that exact name. Without it, the browser shows a certificate warning, which is why you stop at warnings.

13. Device: updates and endpoint protection. Access: authenticated Wi-Fi with a separate guest network. Boundary: firewall rules (default deny, approved admin path only). Data in transit: TLS / valid HTTPS. Server: authentication and authorization (permissions, least privilege). Plus segmentation between guest and staff systems.

14. Stop: do not continue and do not enter credentials. A warning does not say **where** the problem is: the device (wrong clock, malware, intercepting software), the network (a fake hotspot or on-path attacker) or the website (expired or wrong certificate). Try later from a trusted network or device and report it to IT if it continues.